🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 06: Exploiting Broken Object Level Authorization (BOLA) Vulnerability to Manipulate API
```

Scenario

Broken Object Level Authorization (**BOLA**) is ranked as the #1 vulnerability on the OWASP API Security Top 10 list. BOLA occurs when an API endpoint accepts object identifiers (such as database GUIDs, user IDs, or vehicle IDs) in client requests without validating that the authenticated session possesses authorization to access that specific object.

The **OWASP crAPI** platform simulates a B2C automotive application where users manage personal vehicles and community posts. While vehicle details are restricted per user, public community post API responses leak user object identifiers (**vehicleId**). By swapping their own vehicle identifier with a harvested victim **vehicleId** in API endpoints like `/identity/api/v2/vehicle/<vehicleId>/location`, an attacker can extract sensitive real-time location telemetry for any car on the platform.

In this exercise, we initialize crAPI on Ubuntu, extract vehicle credentials via Mailhog (**http://192.168.0.19:8025**), harvest victim vehicle identifiers from public community API responses in Burp Suite, and exploit BOLA to access unauthorized vehicle location data.

Objective

The objective of this lab is to help students learn how to:
- Deploy and configure containerized microservices suites (crAPI) and email interception tools (Mailhog)
- Retrieve vehicle PIN/VIN details from internal Mailhog dashboards (**http://192.168.0.19:8025**)
- Intercept and inspect API request/response structures in Burp Suite Proxy HTTP history
- Harvest sensitive object identifiers (**vehicleId**) from unauthenticated or public community post API responses
- Manipulate API object identifiers in Burp Repeater to exploit BOLA and retrieve unauthorized user data

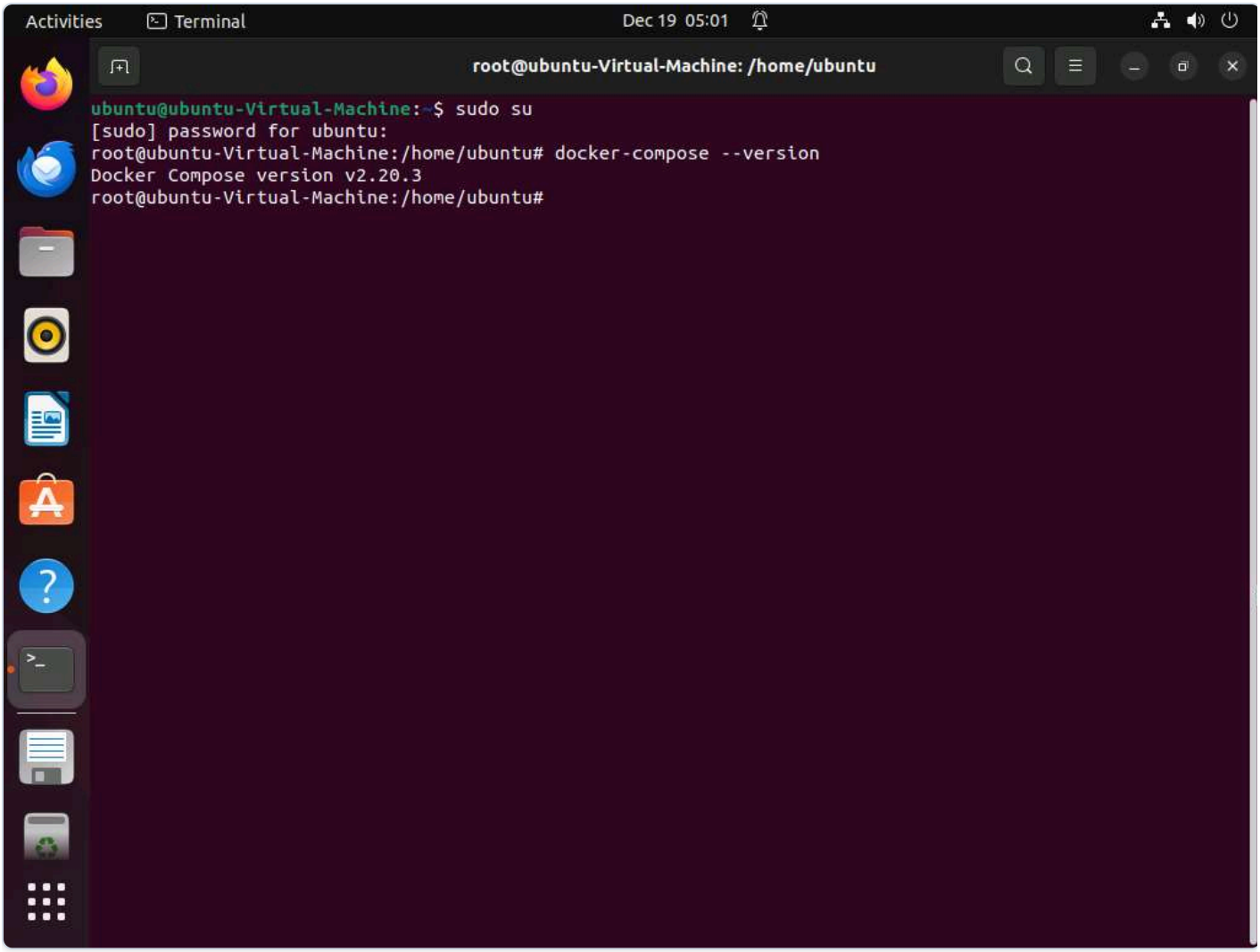
---

Task 1: Deploy crAPI and Exploit BOLA API Endpoints

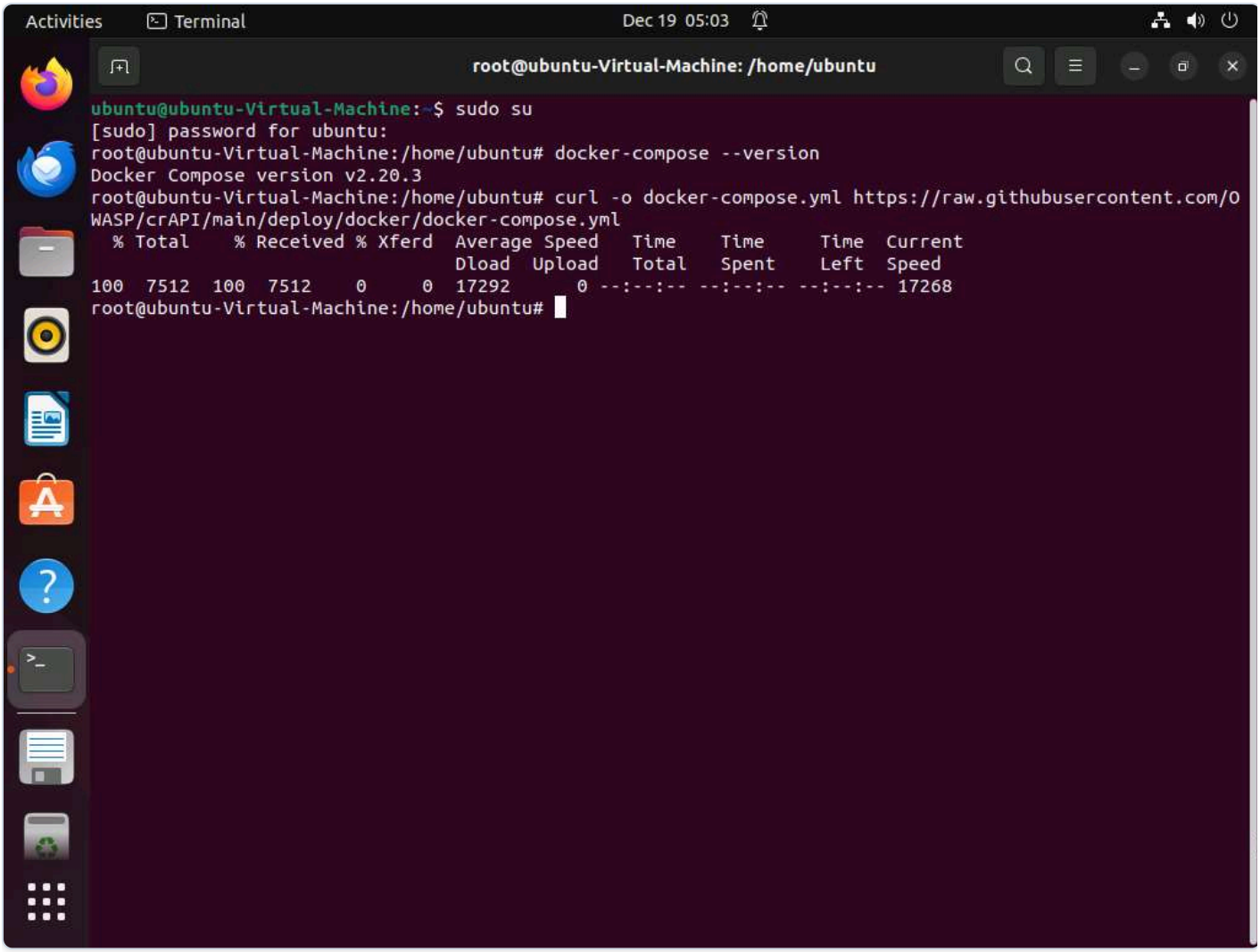
In this task, we launch crAPI on Ubuntu, retrieve registration verification codes via Mailhog on port 8025, extract victim vehicle IDs from Community posts, and manipulate vehicle location API requests in Burp Repeater.

Lab Tasks

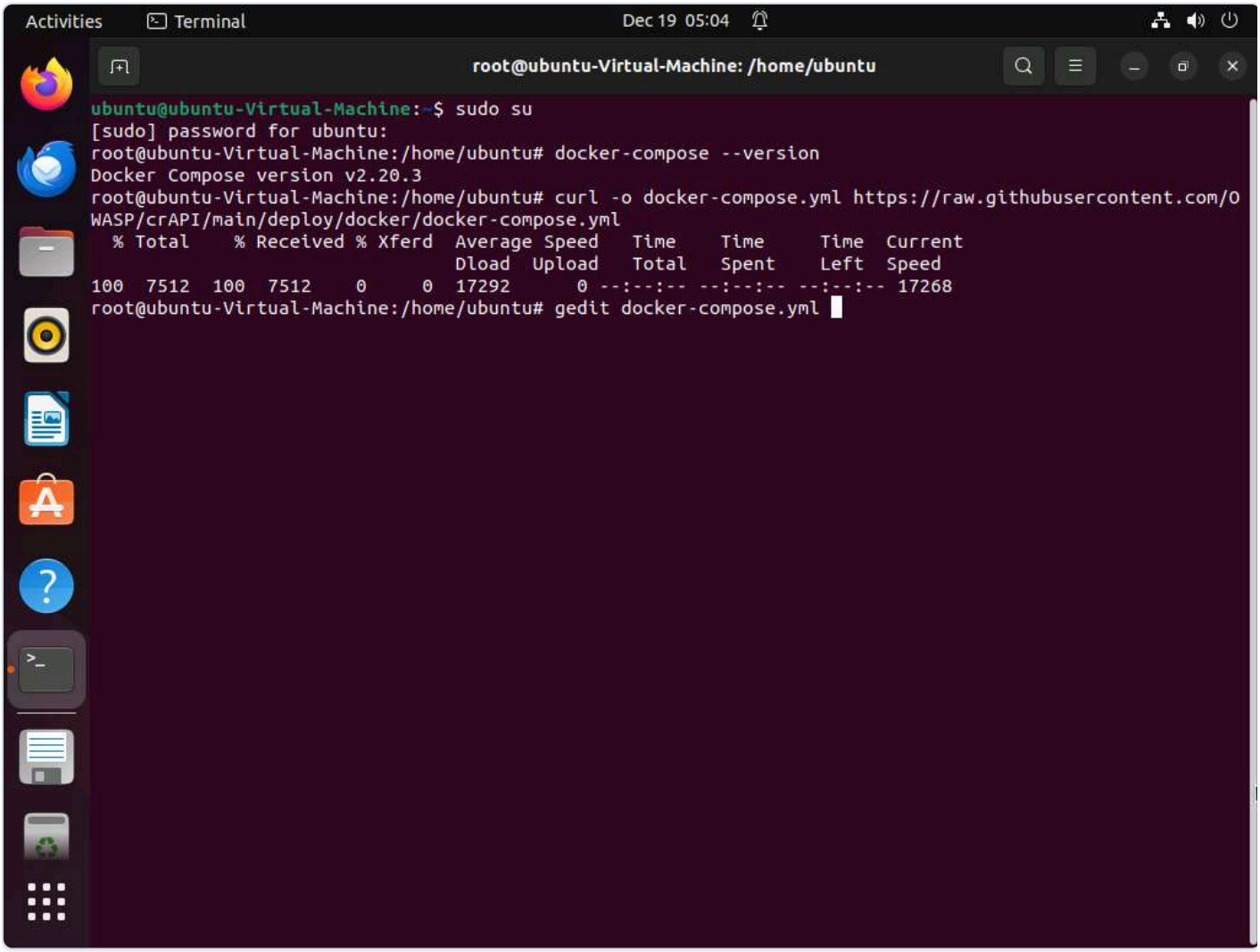
1. Switch to **Ubuntu** (**ubuntu** / **toor**), open a terminal elevated to root (**sudo su**), and check Docker Compose:
   docker-compose --version

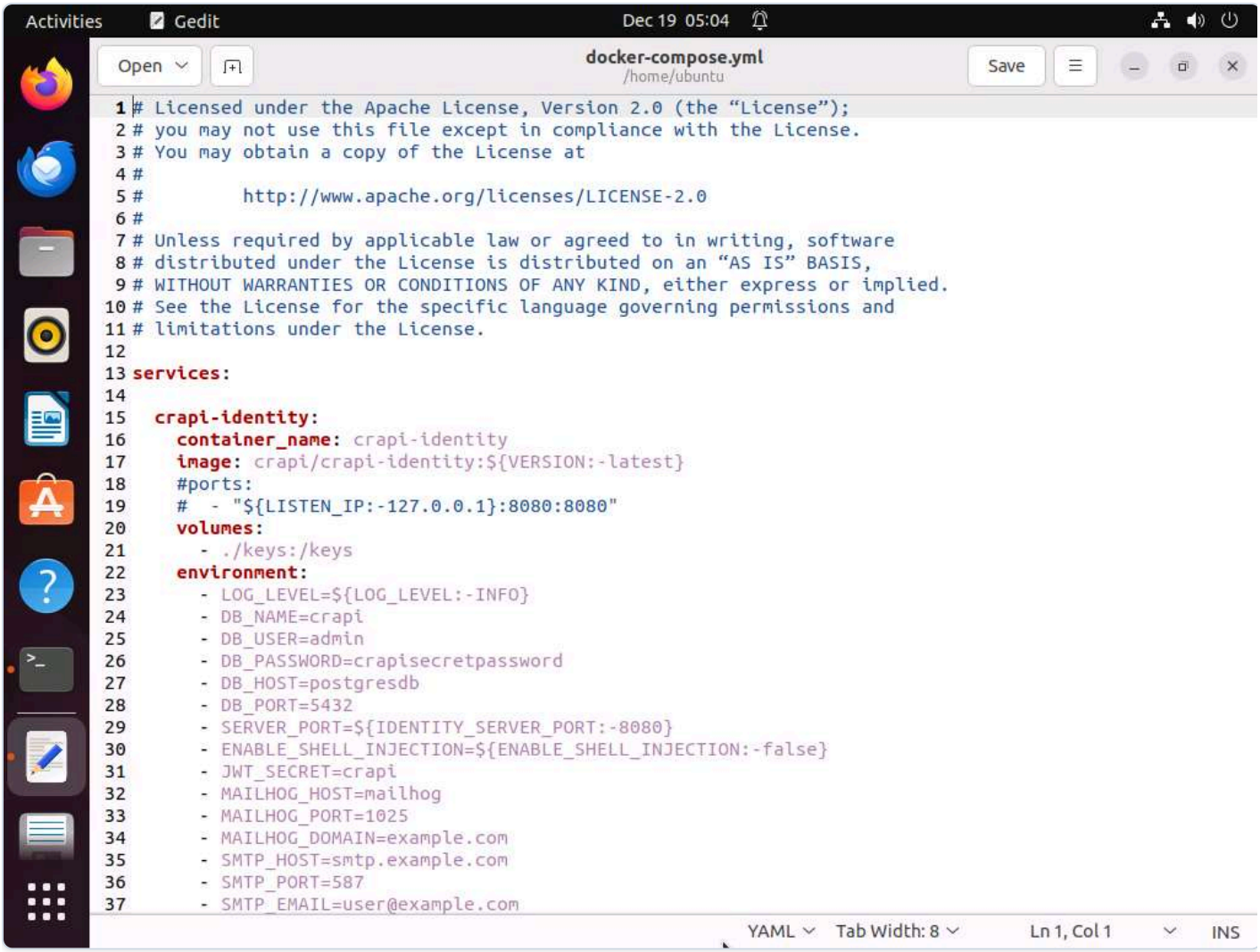


1. Download the OWASP crAPI deployment compose file:
   curl -o docker-compose.yml https://raw.githubusercontent.com/OWASP/crAPI/main/deploy/docker/docker-compose.yml

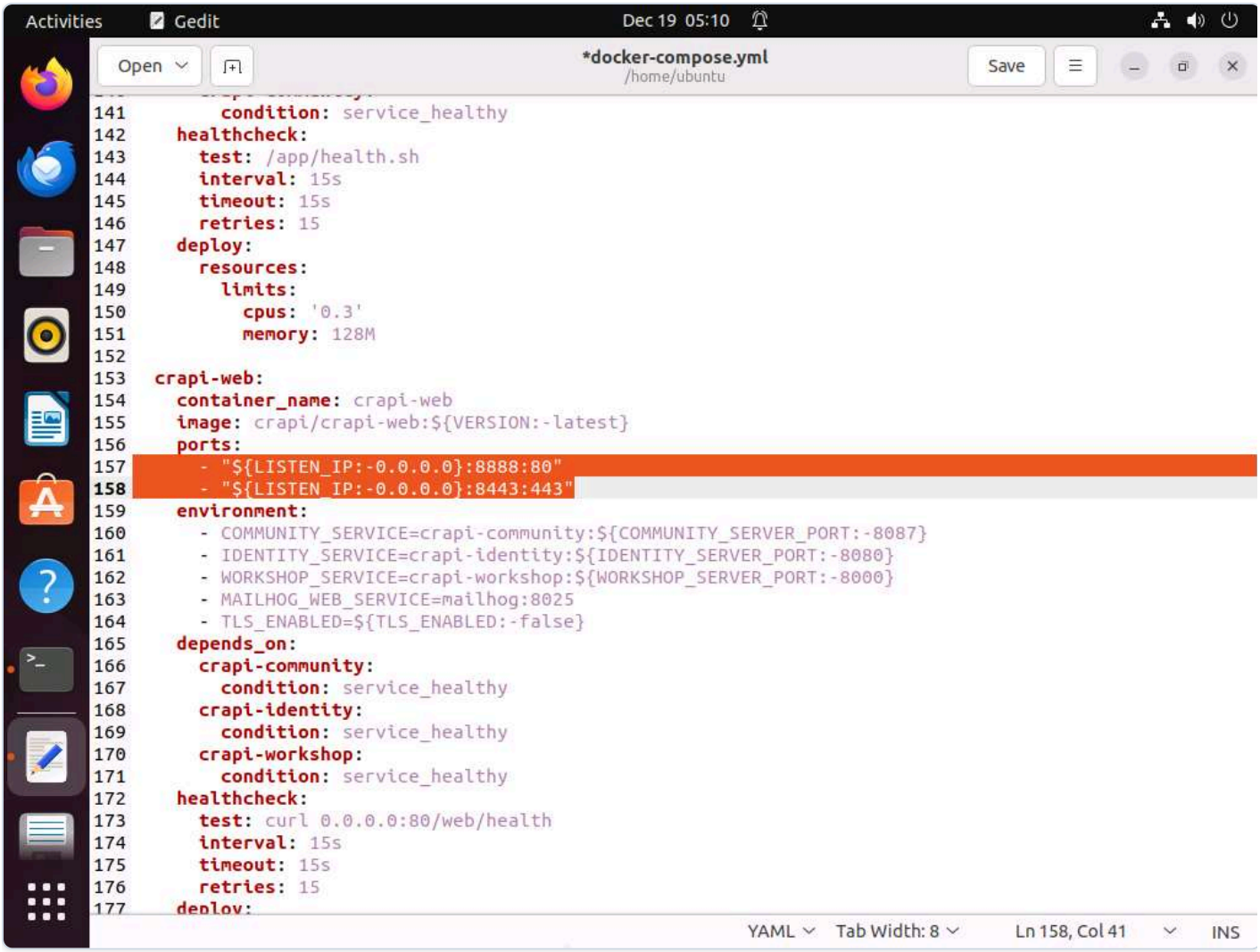


1. Open `docker-compose.yml` in gedit:
   gedit docker-compose.yml

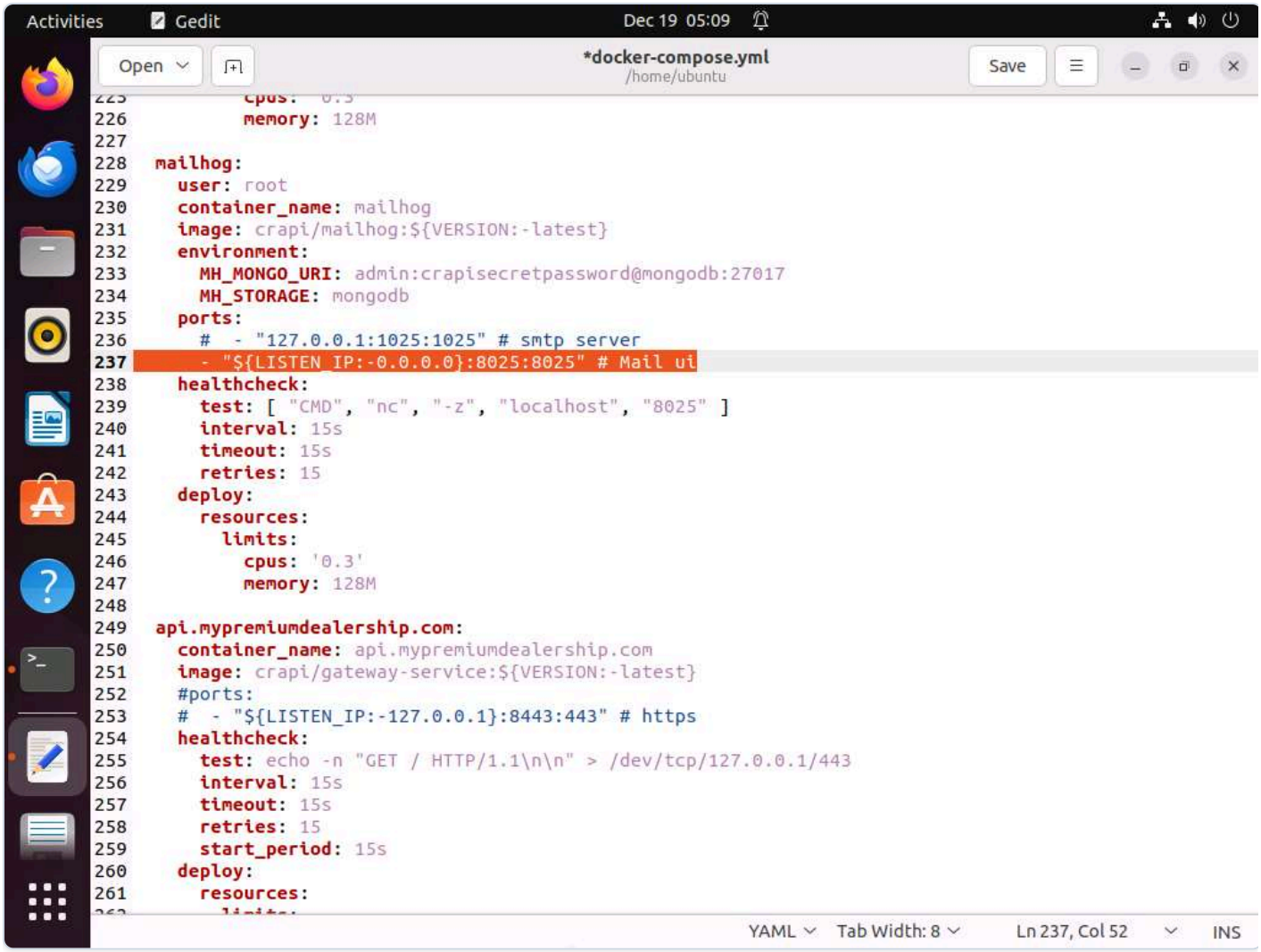

Activities
Terminal
Dec 19 05:04
root@ubuntu-Virtual-Machine: /home/ubuntu
ubuntu@ubuntu-Virtual-Machine:~$ sudo su
[sudo] password for ubuntu:
root@ubuntu-Virtual-Machine:/home/ubuntu# docker-compose --version
Docker Compose version v2.20.3
root@ubuntu-Virtual-Machine:/home/ubuntu# curl -o docker-compose.yml https://raw.githubusercontent.com/OWASP/crAPI/main/deploy/docker/docker-compose.yml
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 7512 100 7512 0 0 17292 0 --:--:-- --:--:-- --:--:-- 17268
root@ubuntu-Virtual-Machine:/home/ubuntu# gedit docker-compose.yml



1. Update the `crapi-web` service section (line 157) to bind port `8888:80`.

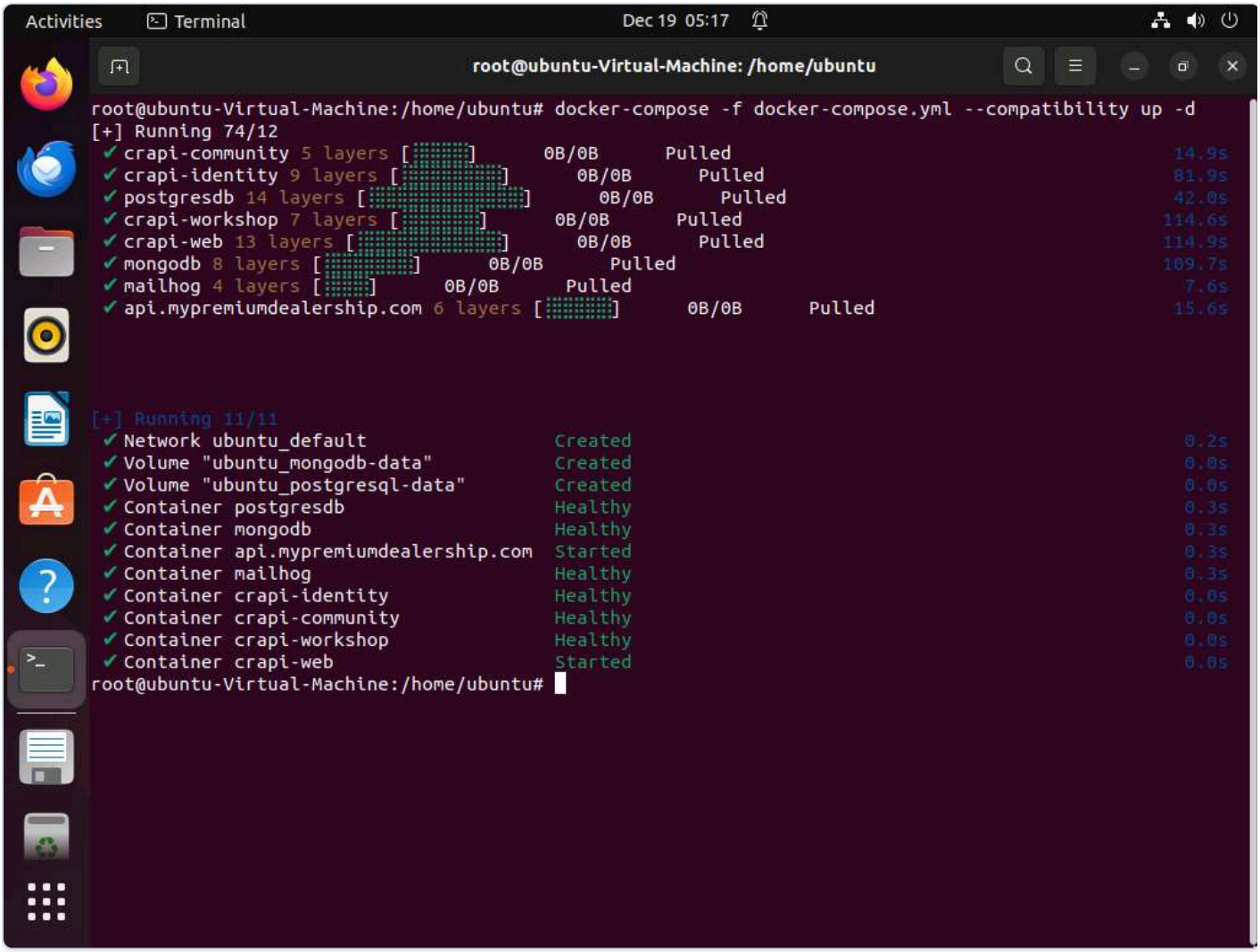


1. Update the `mailhog` service section (line 237) to bind port `8025:8025`.



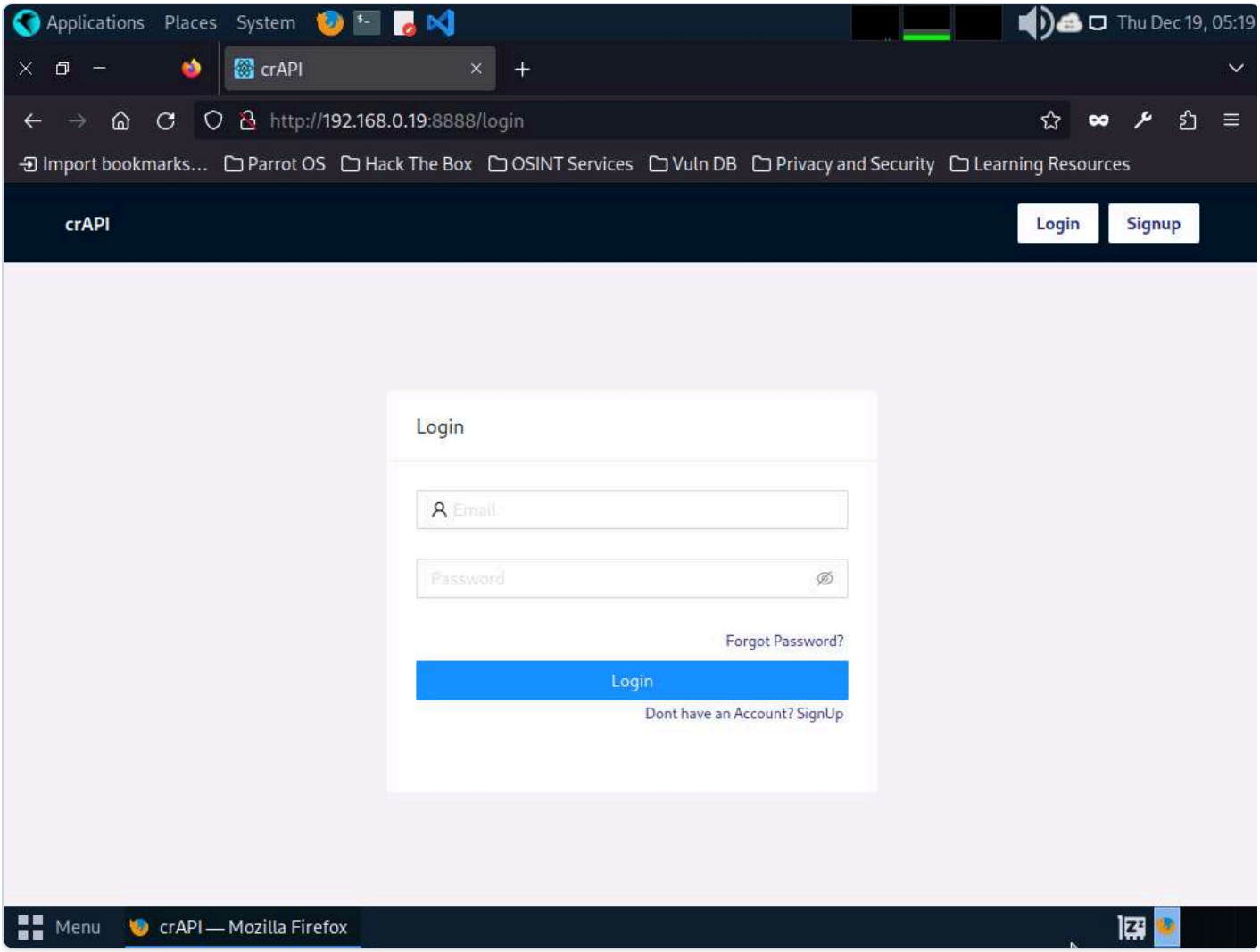
1. Save and close `docker-compose.yml`.
2. Launch the crAPI container services:

   sudo docker-compose -f docker-compose.yml --compatibility up -d

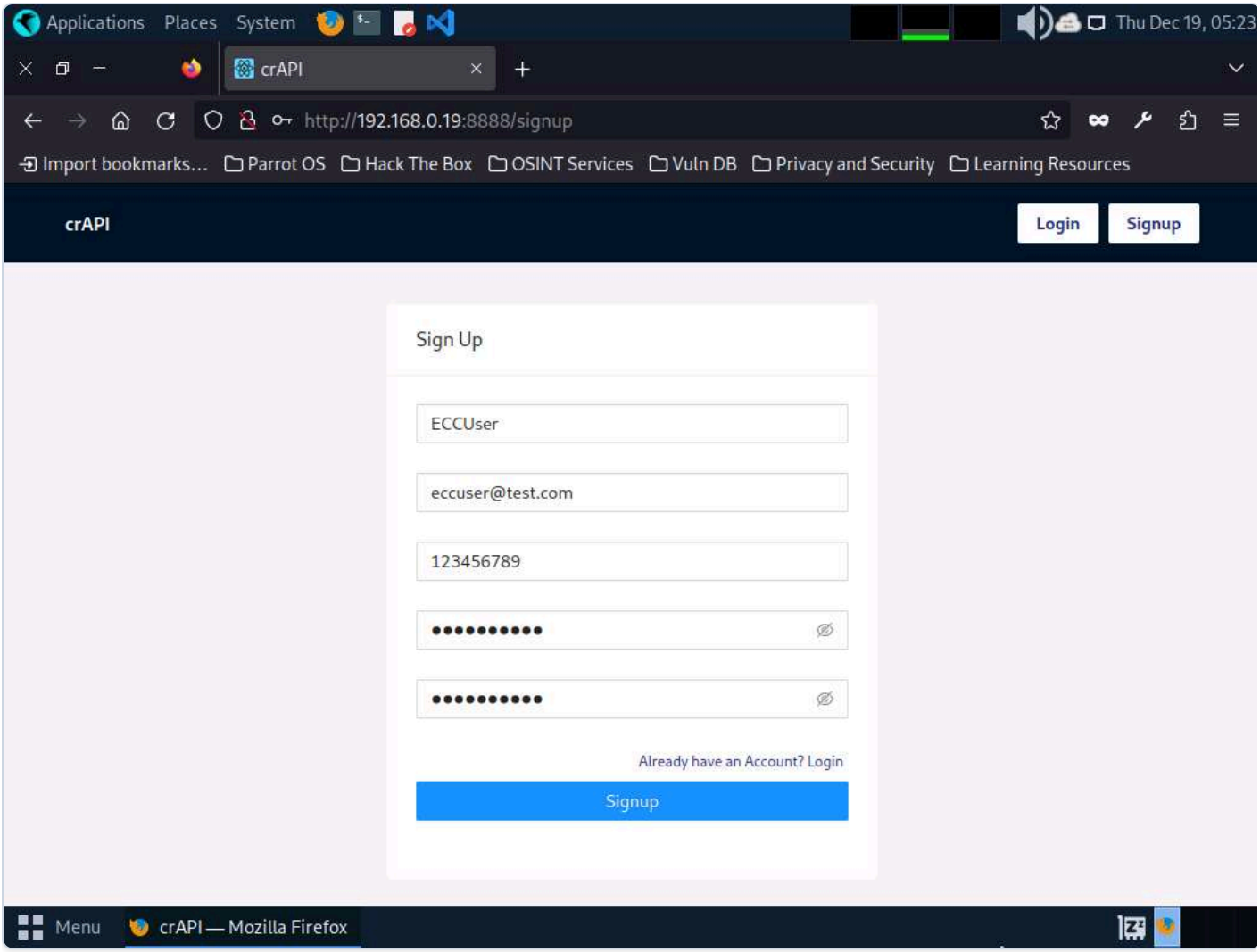


1. Switch to **Parrot Security** (**attacker** / **toor**). Open Firefox and navigate to **http://192.168.0.19:8888**.

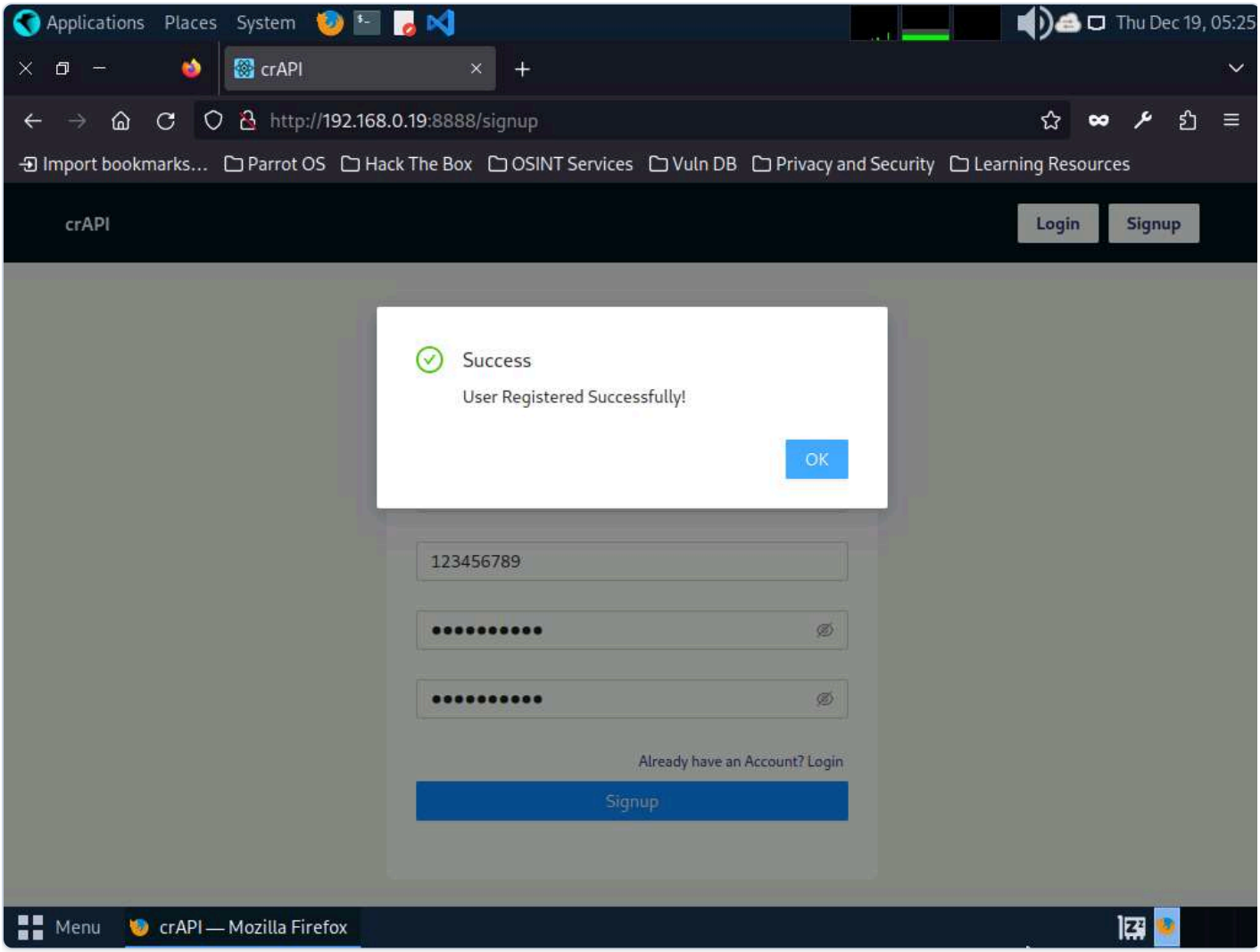
2. Click **Signup** to register a new user account.



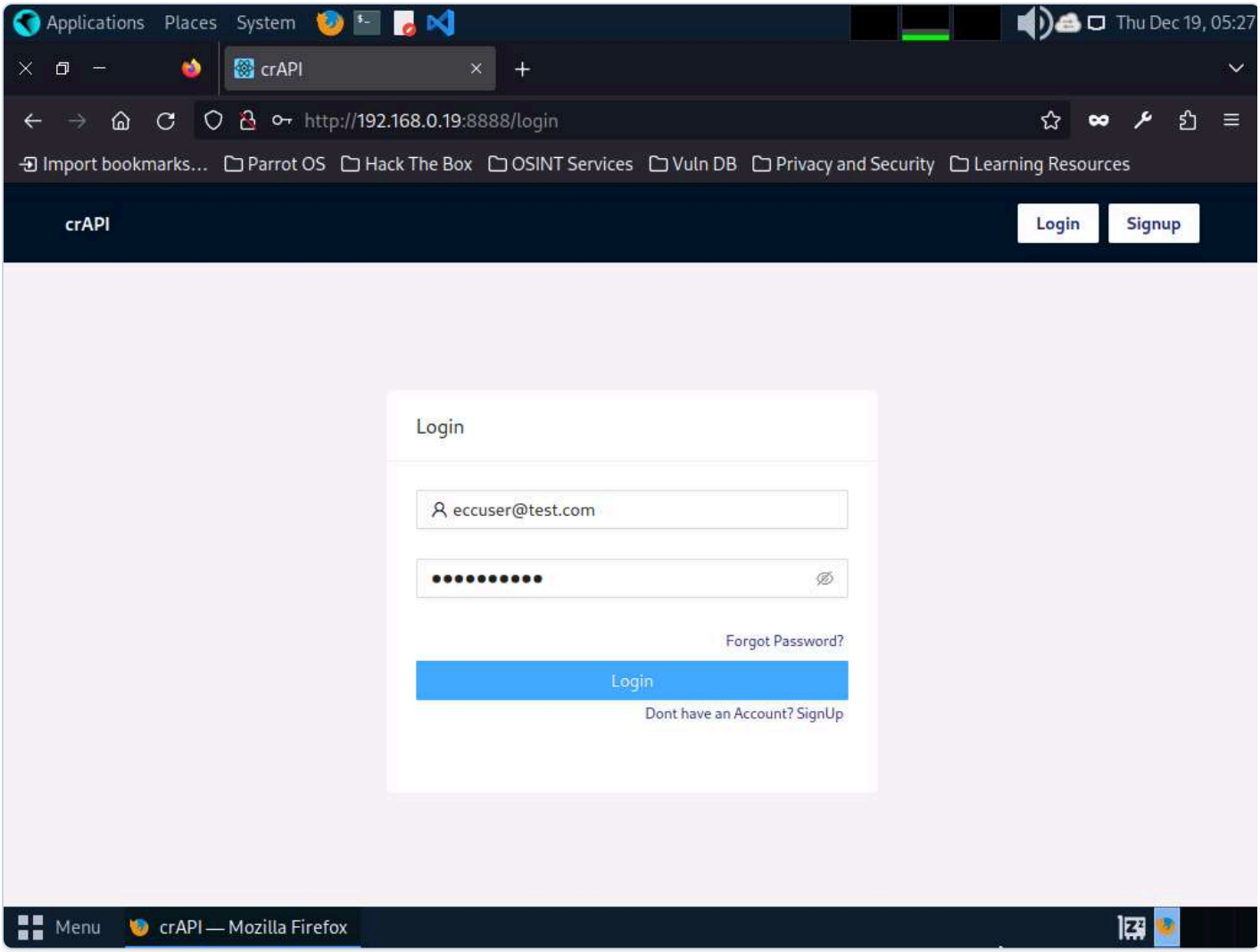
1. Complete the registration form details and click **Signup**.



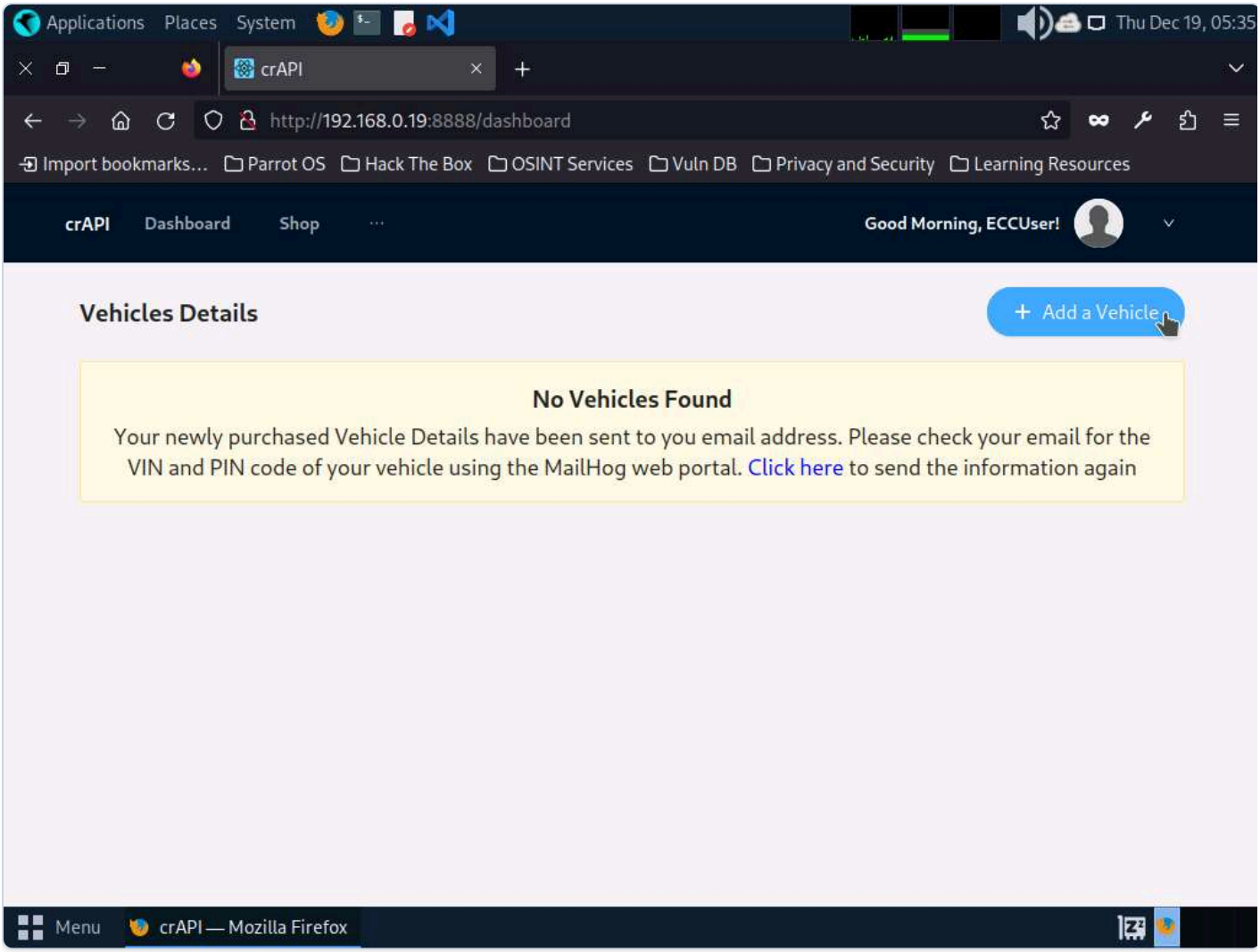
1. Click **OK** on the registration success confirmation dialog.



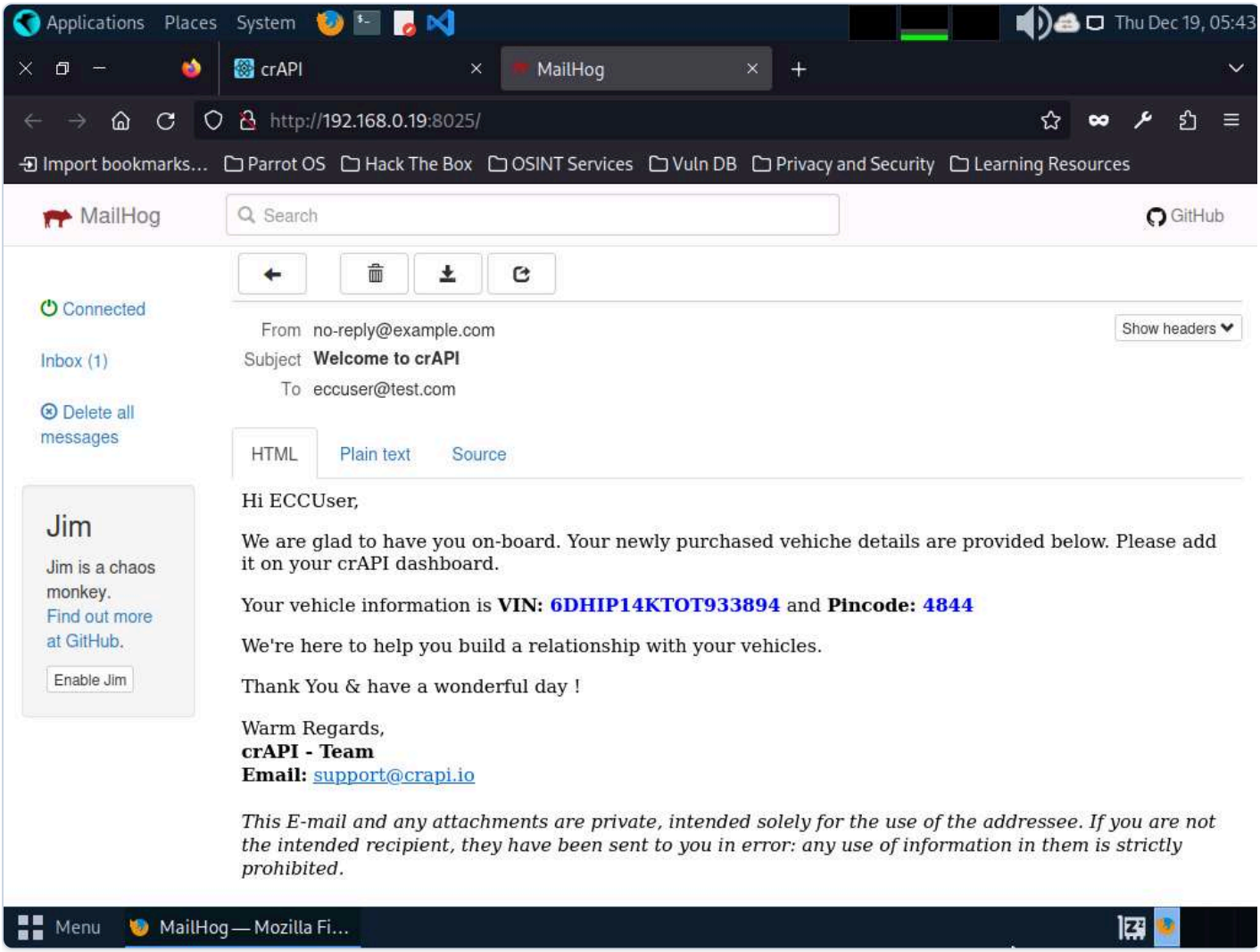
1. Log into crAPI with the newly registered user account.



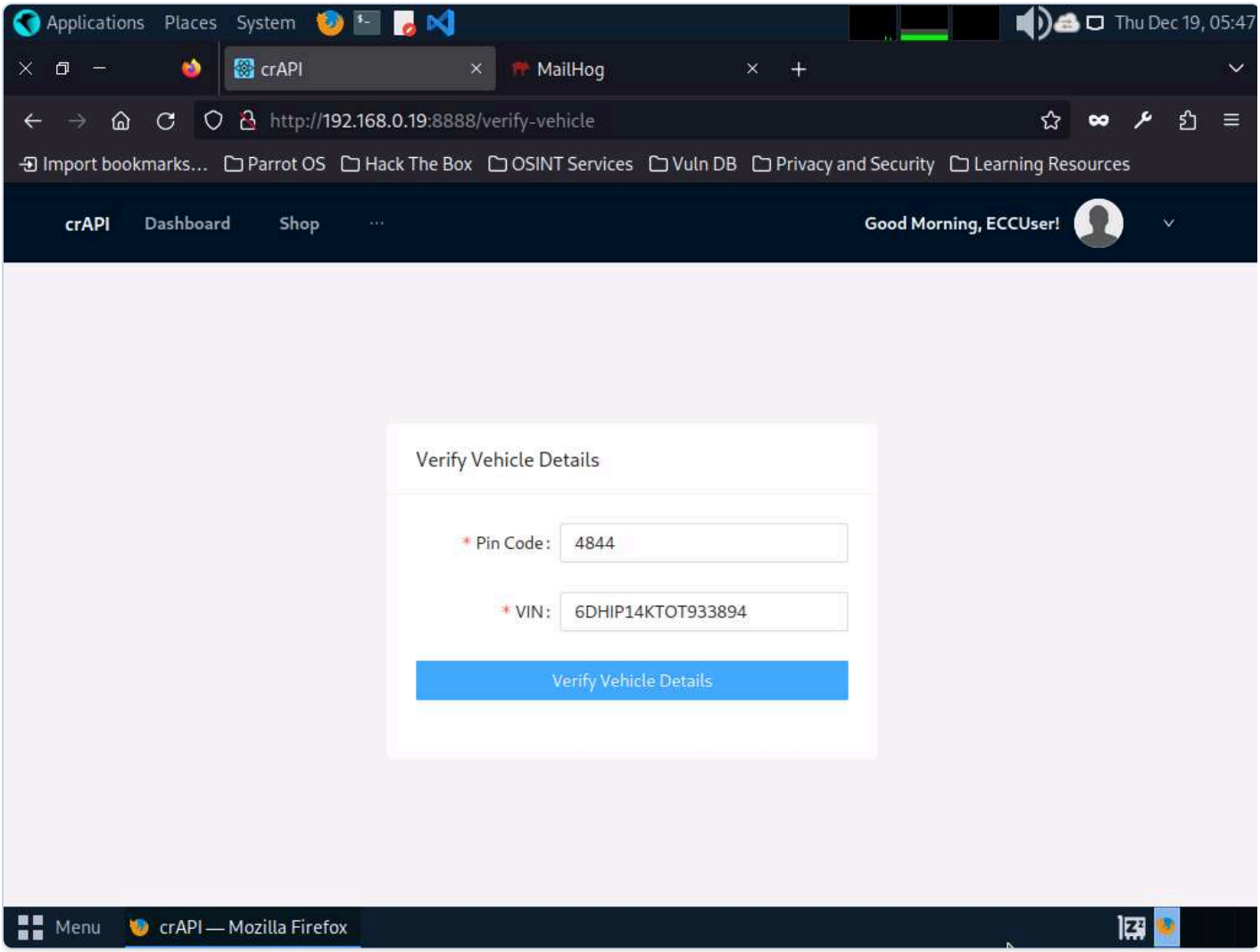
1. On the dashboard, click **+ Add a Vehicle**.



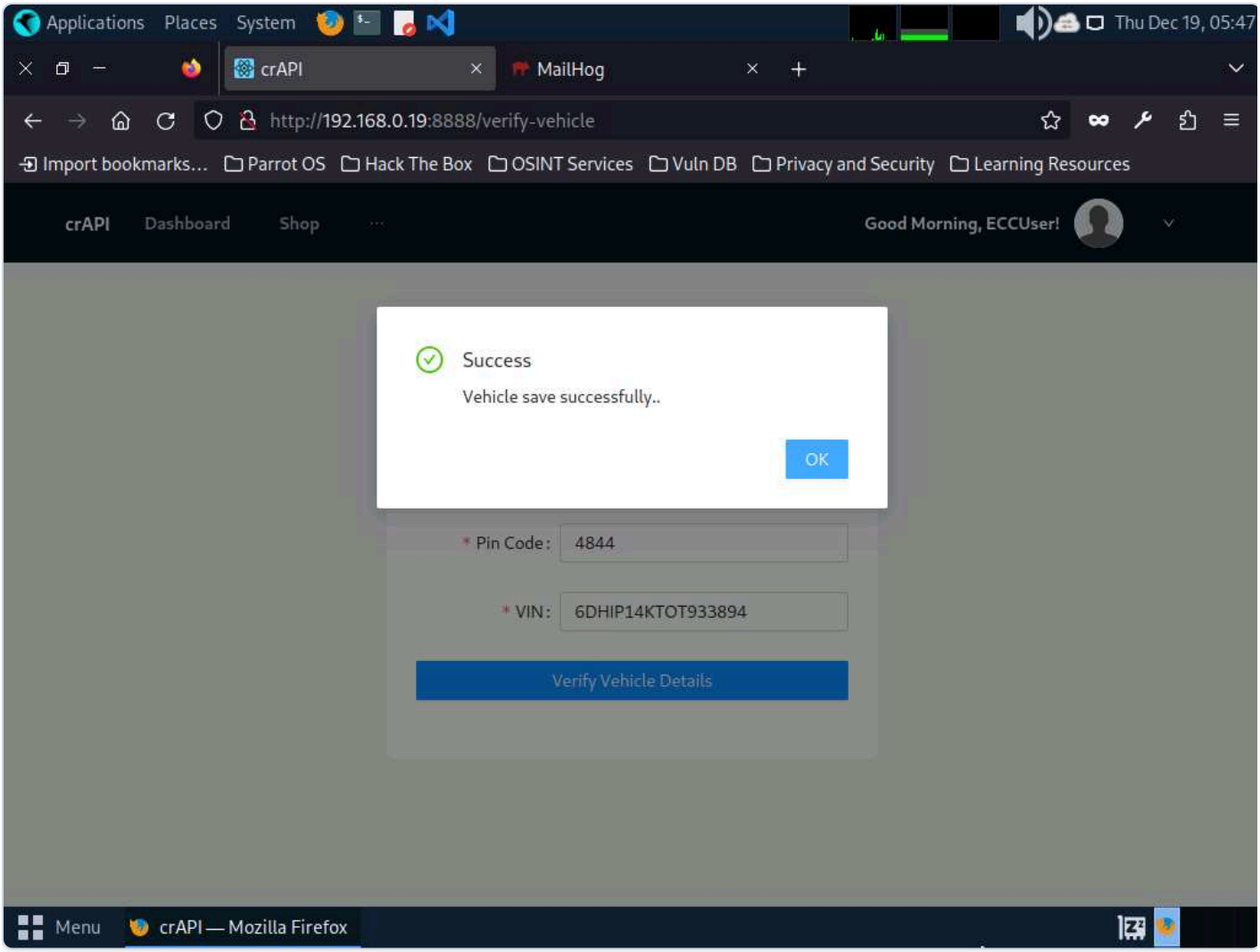
1. Open a new tab in Firefox and navigate to Mailhog service at **http://192.168.0.19:8025** to retrieve the vehicle Pin Code and VIN numbers.

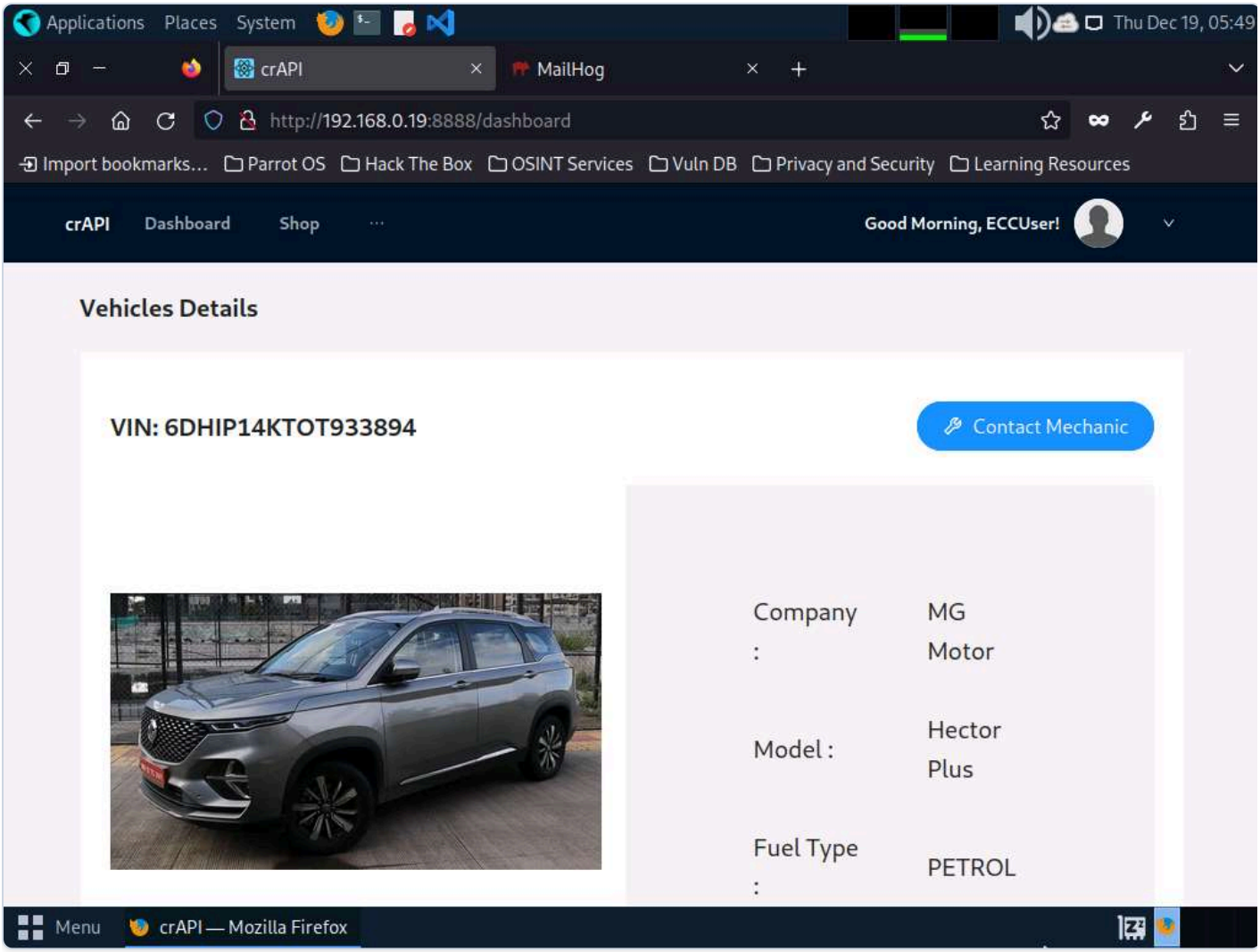


1. Open the received email message and copy the vehicle Pin Code and VIN details.

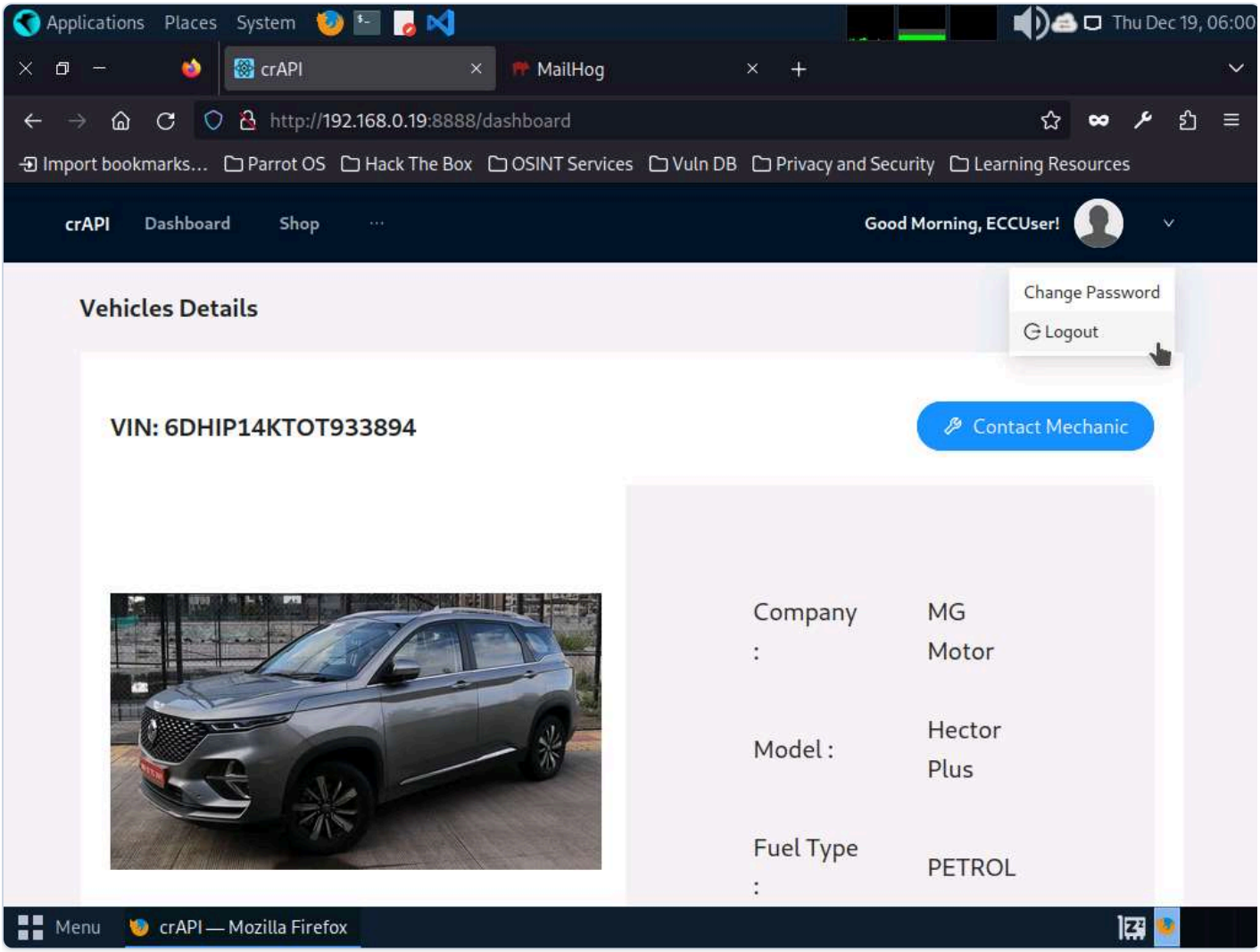


1. Return to crAPI, input the vehicle verification details, and click **Verify Vehicle Details**.

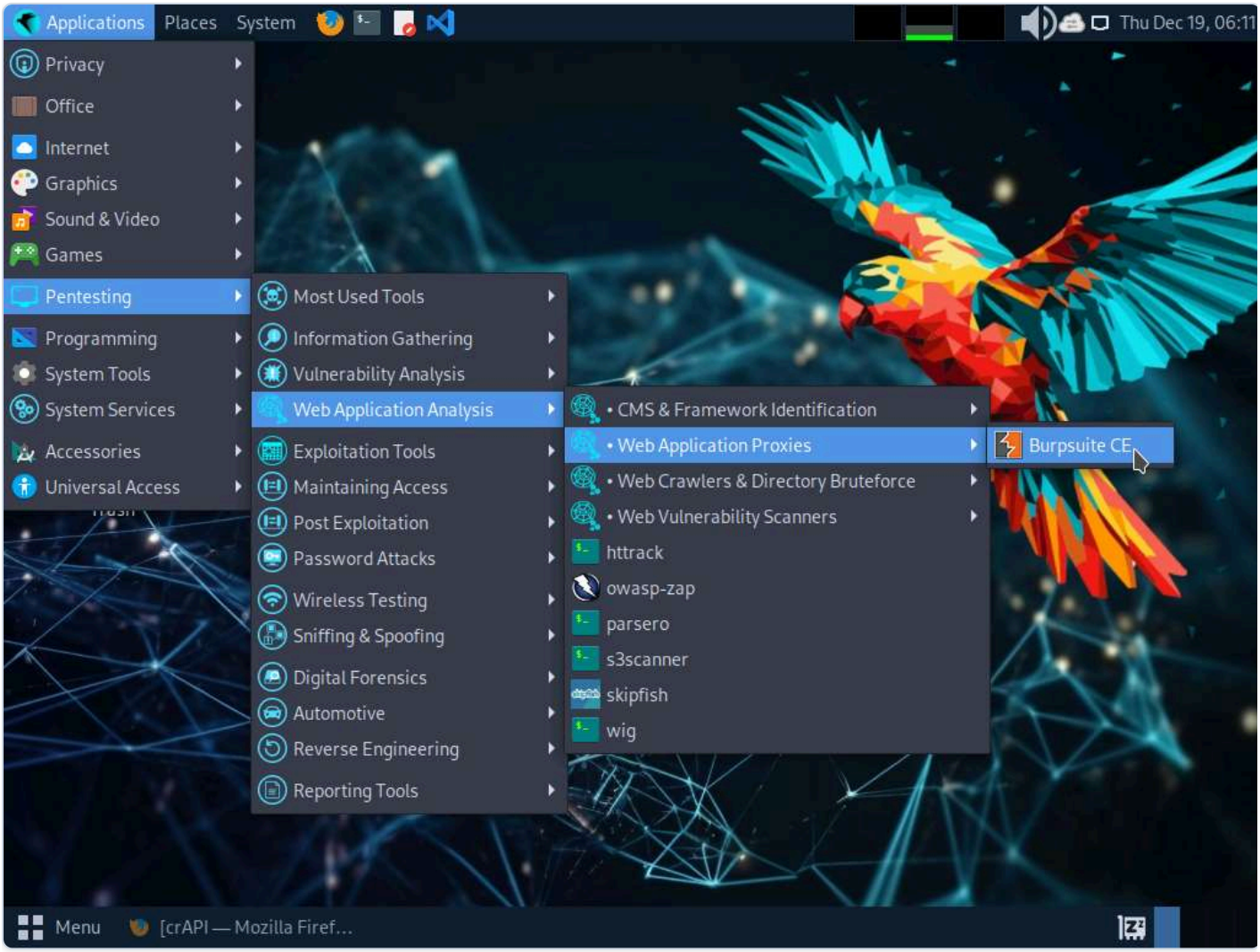

Applications
Places
System
Thu Dec 19, 05:47
crAPI
MailHog
http://192.168.0.19:8888/verify-vehicle
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
crAPI
Dashboard
Shop
Good Morning, ECCUser!
Success
Vehicle save successfully..
OK
* Pin Code:
4844
* VIN:
6DHIP14KTOT933894
Verify Vehicle Details
Menu
crAPI — Mozilla Firefox



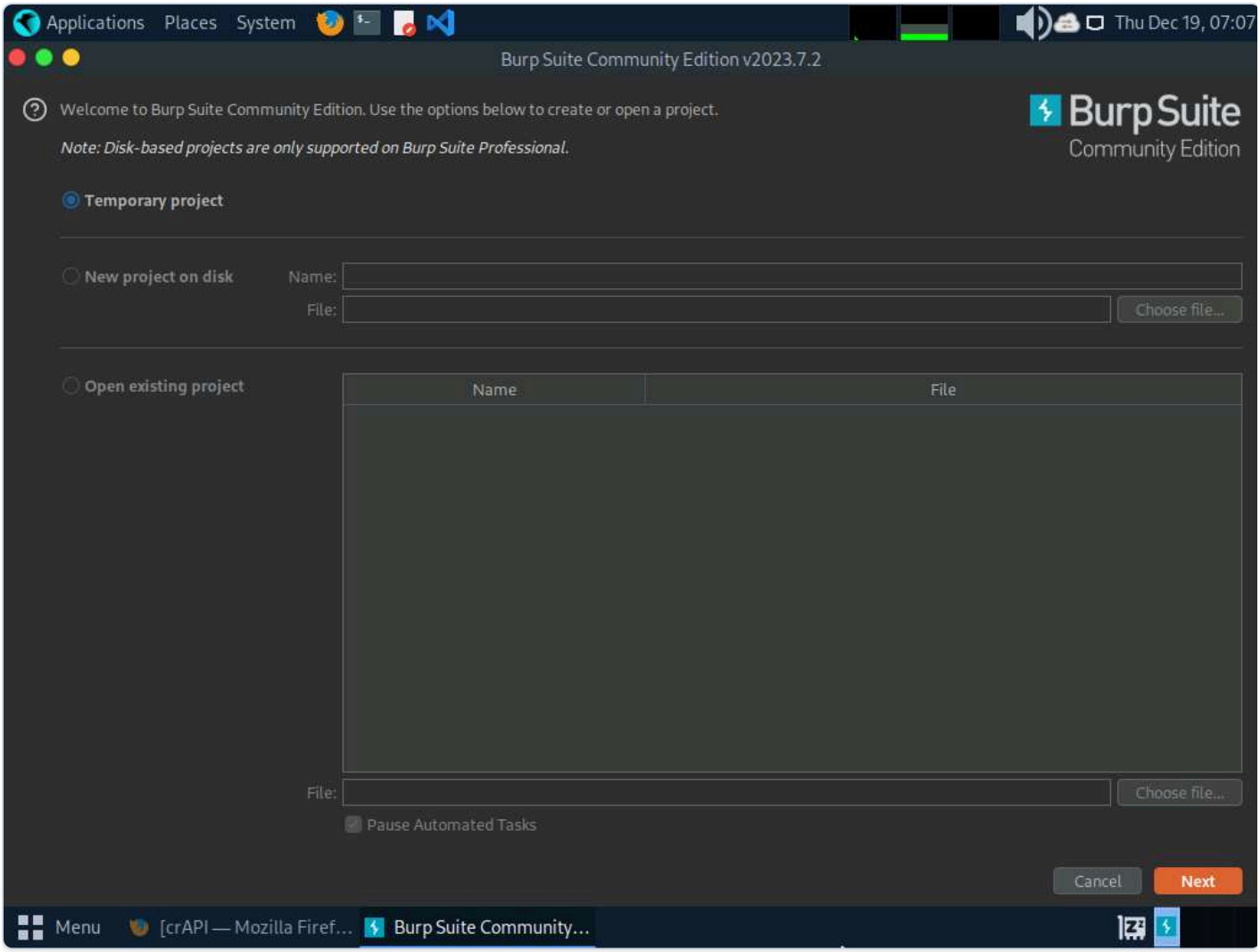
1. Confirm successful vehicle registration display.



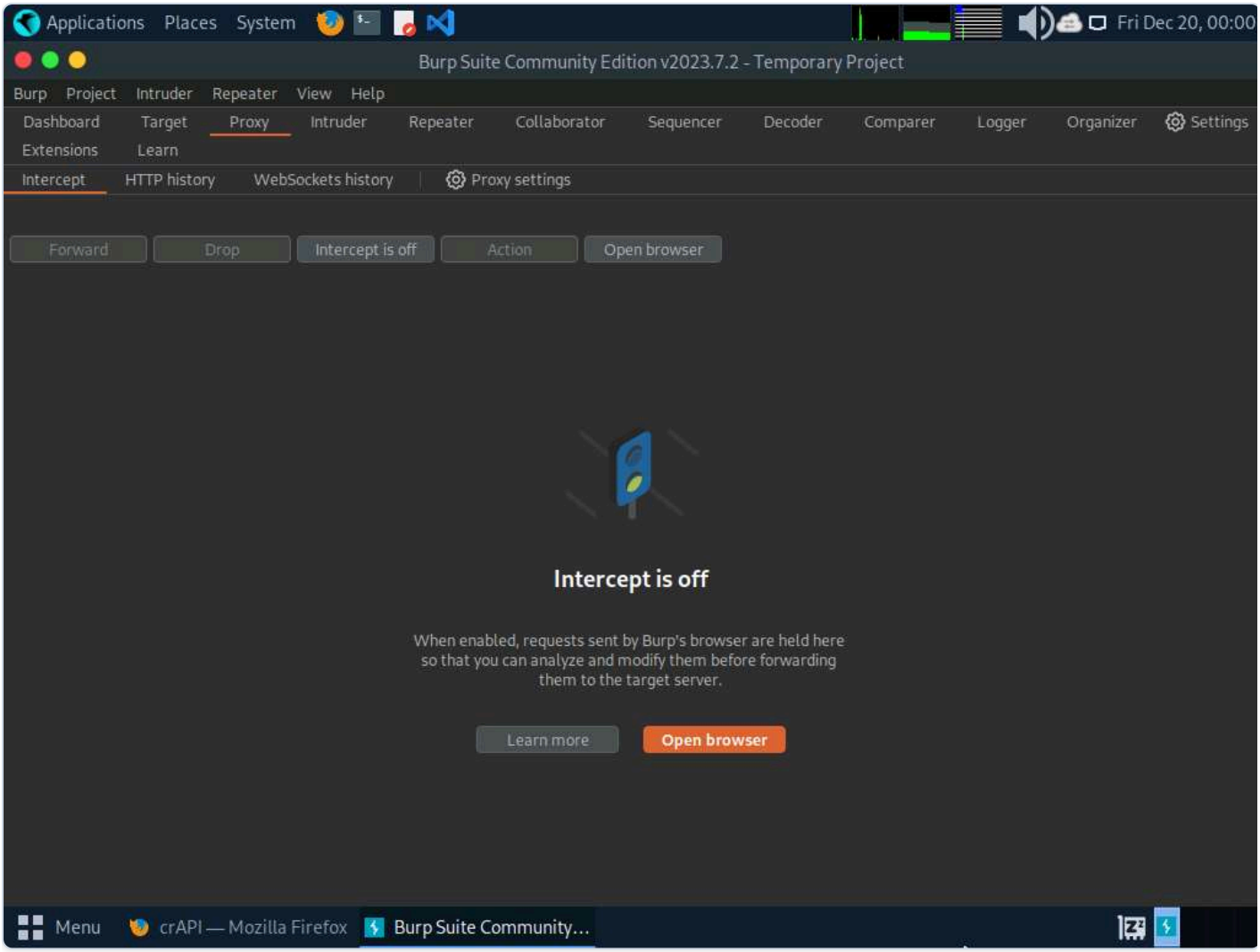
1. Click the user profile dropdown on the top-right and select **Logout**.



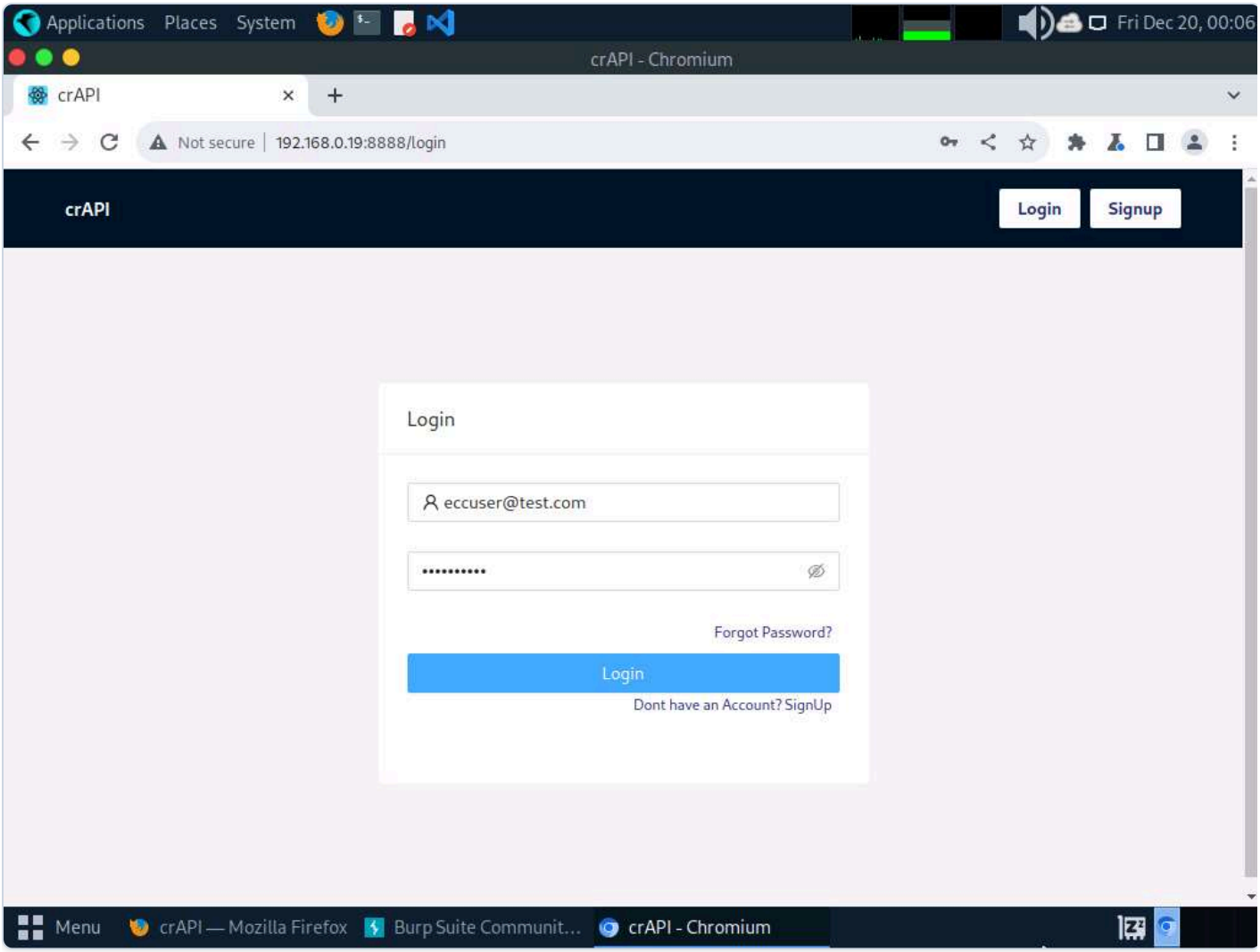
1. Launch **Burp Suite Community Edition** on Parrot Security.



1. Select **Temporary project** and click **Start Burp**.



1. In Burp Proxy, ensure **Intercept is OFF**, and click **Open browser**.



1. In Burp Chromium Browser, open **http://192.168.0.19:8888** and log into crAPI.

Applications Places System Fri Dec 20, 00:06

crAPI - Chromium

crAPI

Not secure | 192.168.0.19:8888/dashboard

crAPI Dashboard Shop ··· Good Morning, ECCUser!

Vehicles Details

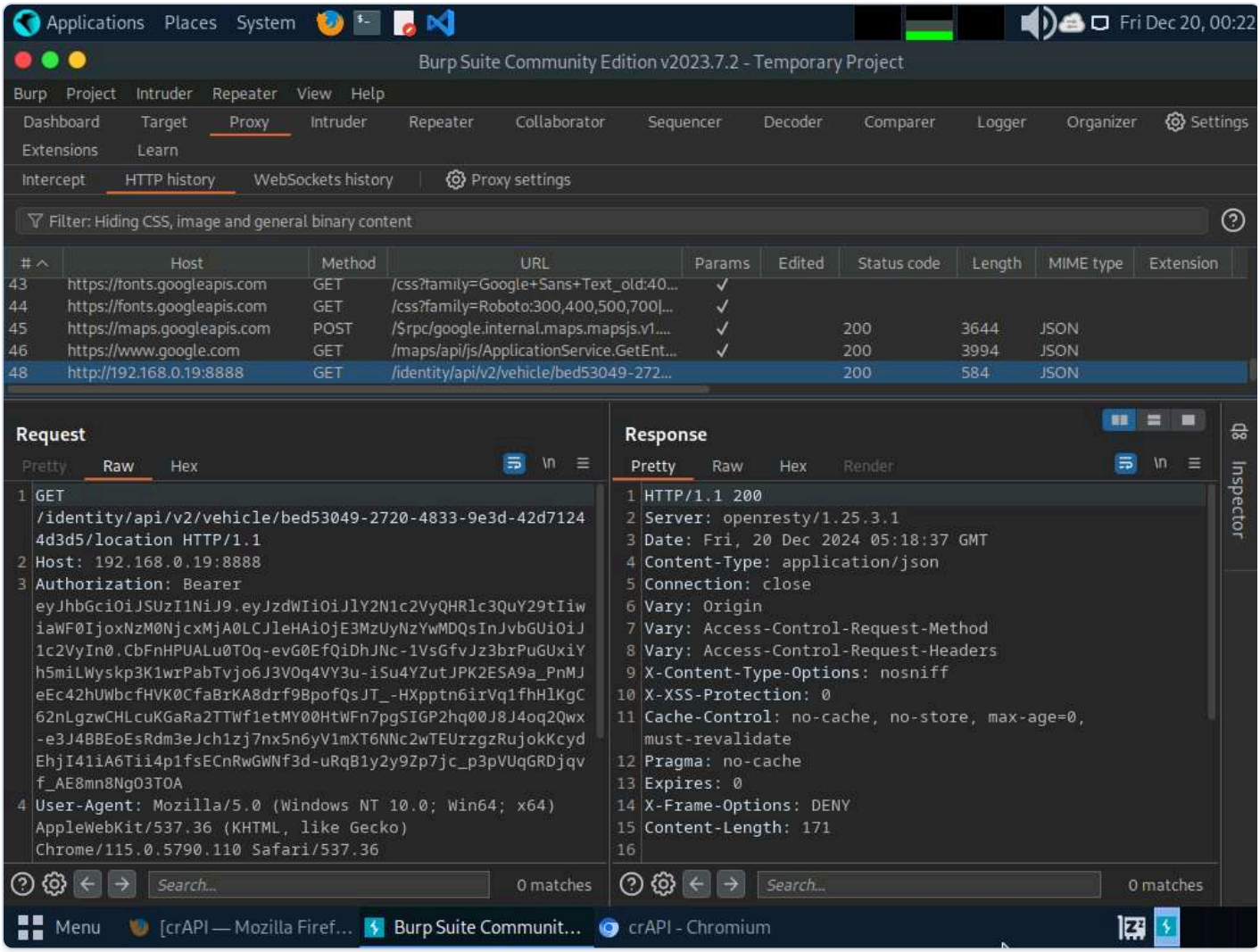
VIN: 6DHIP14KTOT933894

Contact Mechanic

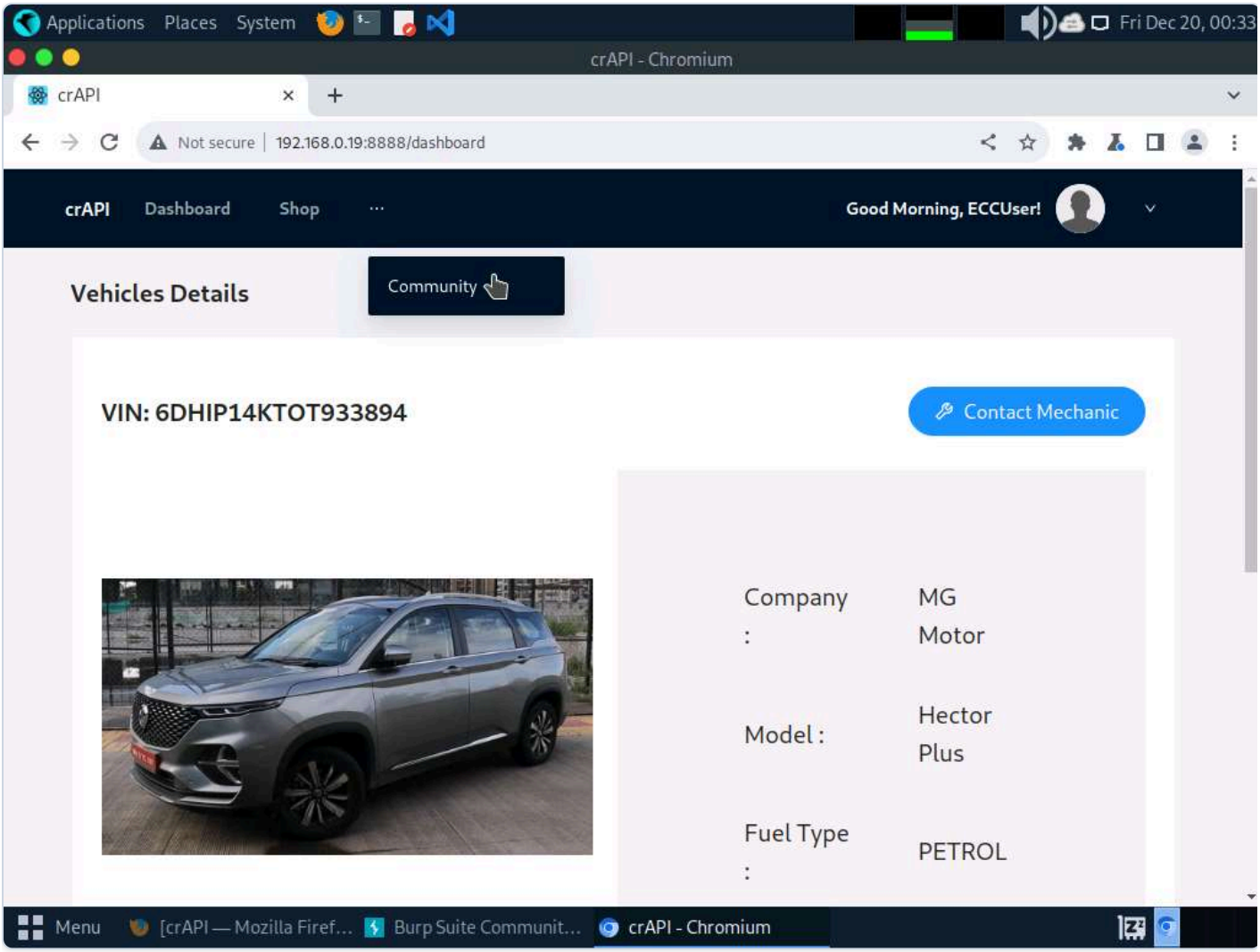


Company :	MG Motor
Model :	Hector Plus
Fuel Type :	PETROL

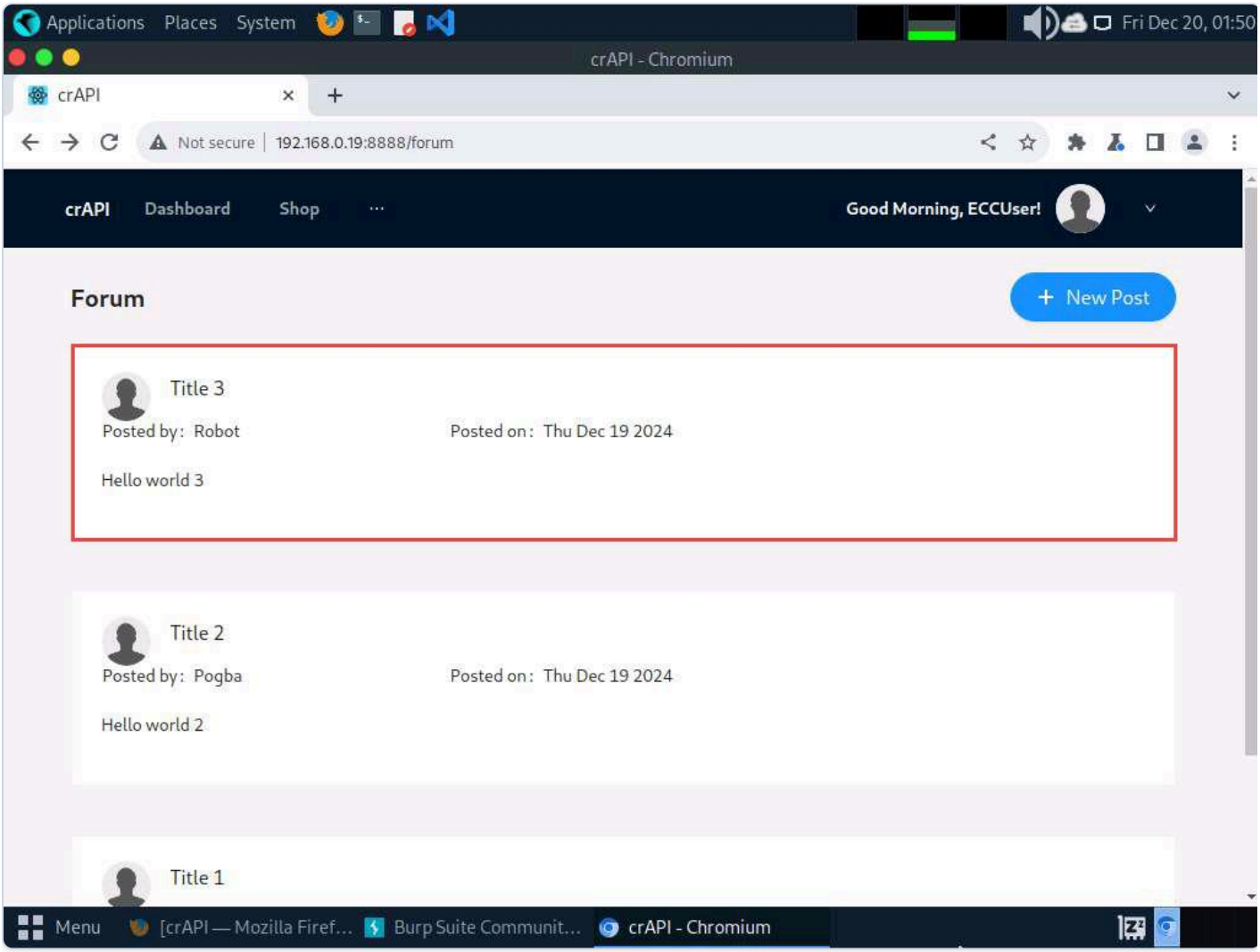
Menu crAPI — Mozilla Firefox Burp Suite Communit... crAPI - Chromium



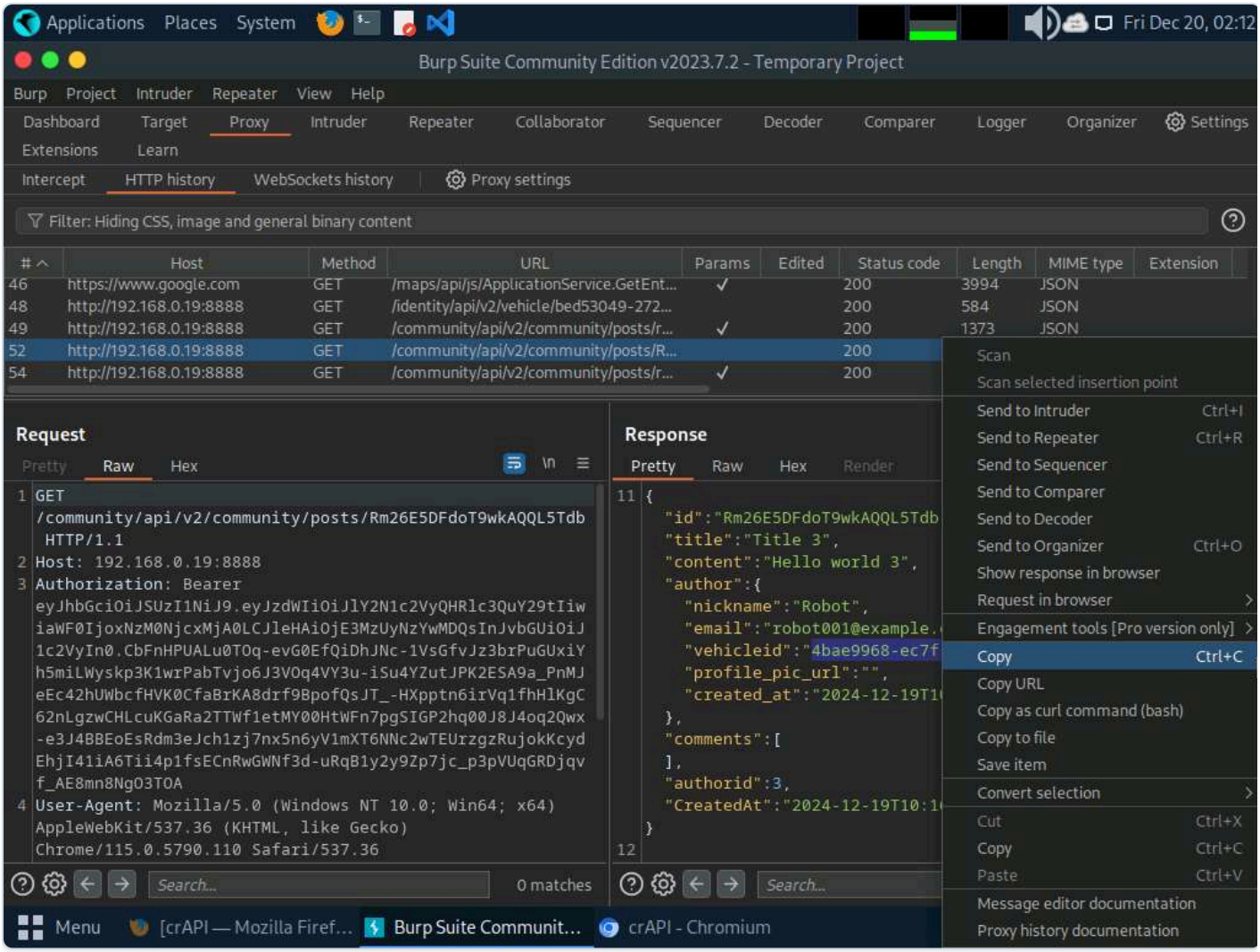
1. Check Burp **HTTP history** tab to identify legitimate vehicle GET requests:
   /identity/api/v2/vehicle/vehicles



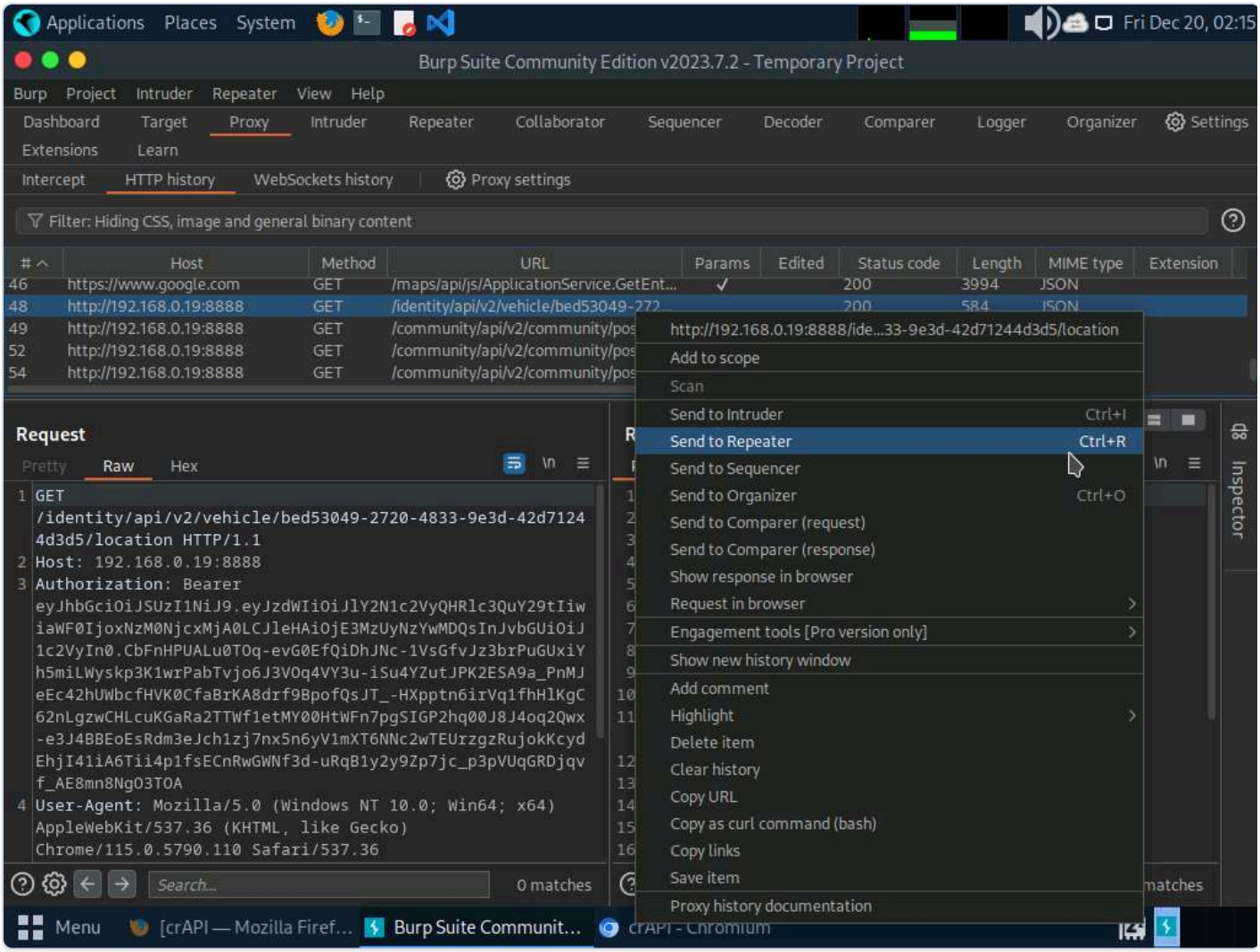
1. Navigate to the **Community** tab on crAPI and open any public post.



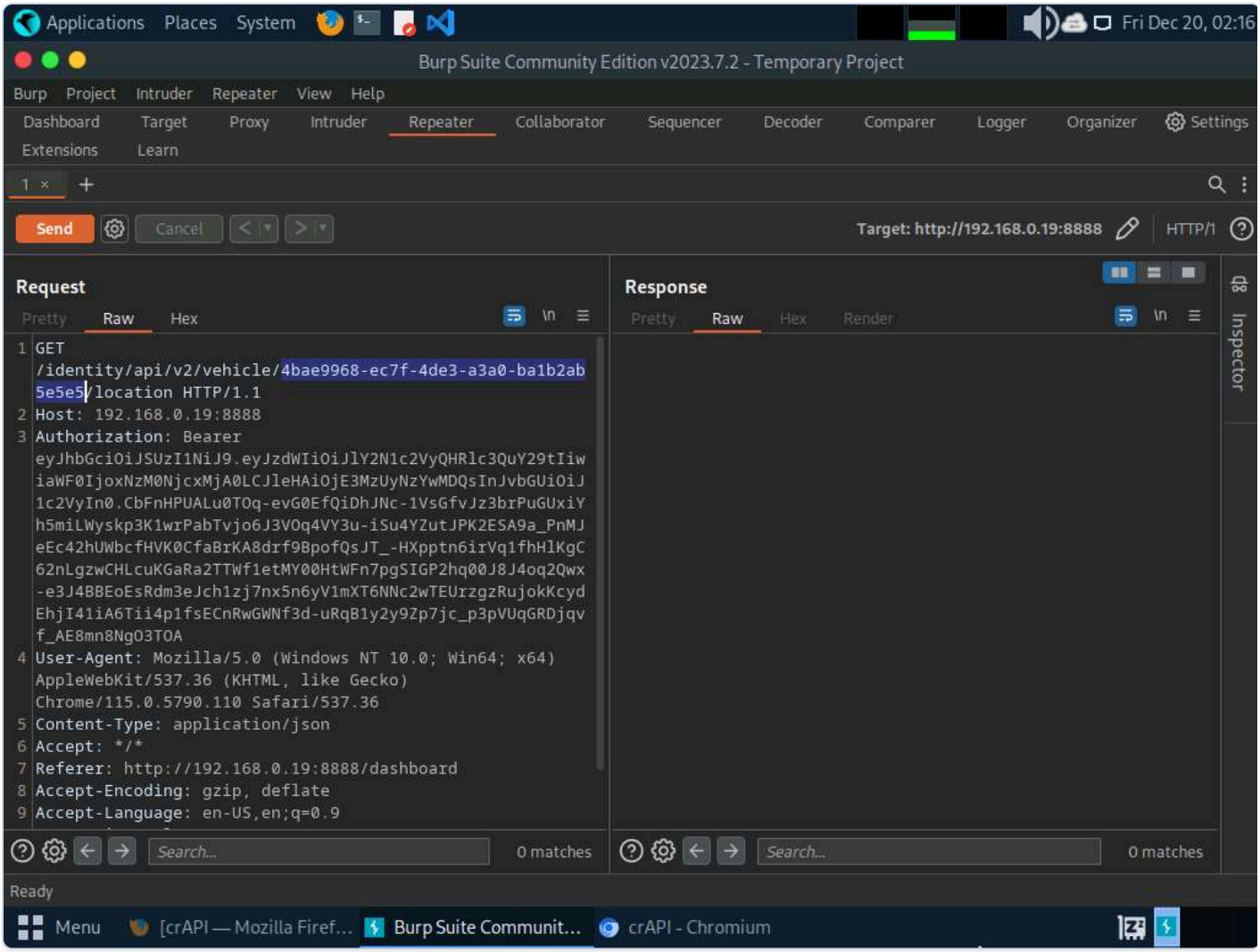
1. Inspect the HTTP history response for the community post to locate another user's exposed **vehicleId**. Copy the victim's **vehicleId**.



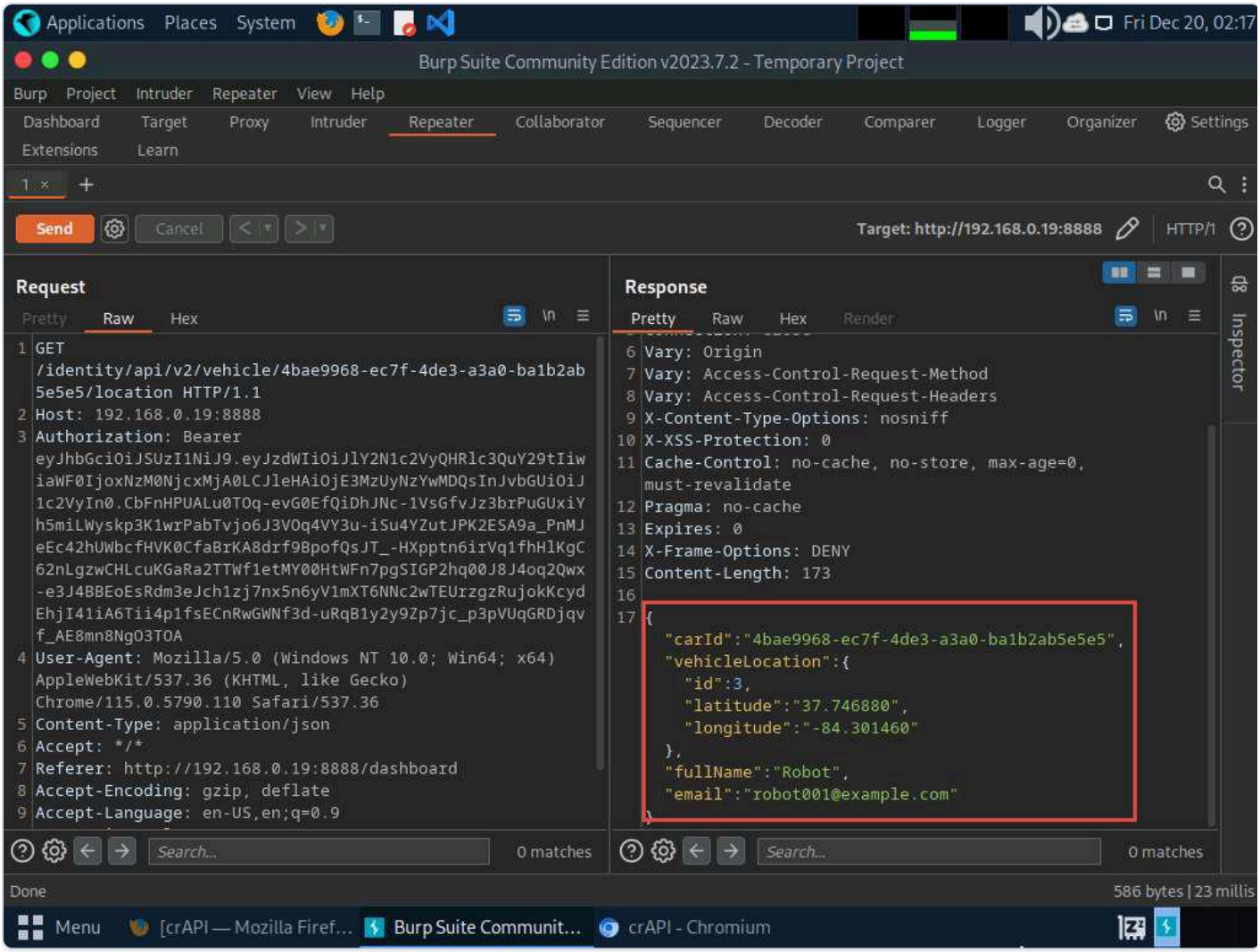
1. Locate the legitimate vehicle location request in HTTP History, right-click, and select **Send to Repeater**.



1. In the Repeater tab, replace your vehicle ID parameter in the request URI with the copied victim **vehicleId**.



1. Click **Send**. Verify that the server returns HTTP 200 OK containing full latitude and longitude coordinates for the target user's vehicle, proving successful BOLA exploitation.



1. Close all browser and Burp Suite windows.

This concludes the lab exercise.

> **IMPORTANT:** ❓ **Question 6.6.1.1** Set up and execute crAPI on an Ubuntu machine, then access the API from a Parrot Security machine using the OWASP ZAP browser. Identify and exploit the Broken Object Level Authorization (BOLA) vulnerability to retrieve and manipulate sensitive data, such as vehicle IDs. Enter the ip address used to open Mailhog service. [!SUCCESS] ✅ **Answer:** **http://192.168.0.19:8025**